



INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO



TRABAJO TERMINAL 2026-B182

“Esquema preventivo de privacidad para PICIS en la versión de nube basado en la arquitectura Zero Trust”

PRESENTAN

López Carlos Uriel Francisco

Leyva García Diego Alejandro

Romero Carreón Miguel Arturo

DIRECTORES

Dr. Aguirre Anaya Eleazar

Dra. Cortez Duarte Nidia Asunción

Ciudad de México, 27 de mayo de 2026

INTRODUCCIÓN

Cada institución del sector público y privado publica miles de documentos en sus portales. Una proporción no menor contiene, sin advertirlo, **información sensible**: registros personales, credenciales, expedientes médicos o financieros.

Plataforma para detectar antes de que sea tarde

Desarrollada por el Laboratorio de Ciberseguridad del **CIC-IPN**. Automatiza la búsqueda y la catalogación de información sensible publicada inadvertidamente mediante *web scraping* sobre dominios autorizados y un clasificador NLP/IA. Taxonomía operativa: **55 tipos** de información sensible en 10 categorías.

CONTEXT0 · 01

Es cualquier información concerniente a una persona física identificada o identificable. Una persona es identificable cuando su identidad puede determinarse, directa o indirectamente, a través de cualquier información.

Marco metodológico INAI · taxonomía propuesta para la clasificación documental.

Taxonomía · 10 grupos · 55 tipos

De los identificadores a los rasgos físicos

- **Identificadores** · RFC, CURP, teléfono
- **Electrónicos** · email, contraseña
- **Laborales** · email laboral, puesto
- **Tránsito** · pasaporte, visa, placas
- **Patrimonio** · sueldo, núm. de tarjeta
- **Salud** · enfermedades, alergias
- **Académicos** · título, cédula
- **Ideológicos** · religión, afiliación
- **Intimidad** · preferencia sexual
- **Rasgos físicos** · ADN, peso, altura

CONTEXTO · 02

Los **datos personales sensibles** son los relativos a los aspectos más íntimos de la persona — origen racial o étnico, salud, información genética, creencias religiosas, opiniones políticas, preferencia sexual — y su mal uso puede provocar discriminación o un grave riesgo.

Reporte técnico · Cap. 3 · Anexo E — mapeo normativo bidireccional artículo ↔ control.

Sector privado

LFPDPPP

Ley Federal de Protección de Datos Personales en Posesión de los Particulares — regula al sector privado.

Sector público

LGPDPPSO

Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados — regula a más de 340 sujetos obligados en México. **El IPN está entre ellos.**

CONTEXTO · 03

Revisar manualmente si existen datos sensibles publicados en los sitios web de una institución resulta inviable a escala. Para automatizarlo, en el **Centro de Investigación en Computación del IPN** se desarrolló **PICIS** — la Plataforma de Identificación, Clasificación y Monitoreo de Información Sensible.

Su objetivo es **automatizar la identificación** de información sensible publicada en portales y, con ello, apoyar la protección de datos.

PICIS v1 · on-premise

Cómo opera hoy

- *Web scraping* periódico sobre dominios autorizados
- Procesamiento de lenguaje natural
- Inteligencia artificial para clasificación documental
- Ciencia de datos para análisis del corpus
- Validación humana del **Analista** (rol RBAC)

Instalación local · *data center* propio.

CONTEXTO · 04

El CIC-IPN está migrando PICIS a la nube en una nueva versión **v2** que se construye bajo el paradigma *privacy and security by design*. Esta migración es el escenario en el que vive este Trabajo Terminal.

PICIS v1

On-premise

- Servidores propios del laboratorio
- Perímetro de red físico
- Identidades con claves estáticas
- Auditoría local en disco

PICIS v2 · este TT

En la nube — Google Cloud Platform

- Infraestructura gestionada en GCP
- **Perímetro lógico** Zero Trust
- Federación de identidades sin claves
- Auditoría inmutable WORM

PROBLEMÁTICA

La versión *on-premise* opera tras un perímetro de red físico. Al pasar a Google Cloud Platform tres propiedades que se daban por hechas dejan de cumplirse y deben reconstruirse explícitamente.

Problema 01

Perímetro lógico disuelto

La red corporativa ya no protege los recursos. Cada solicitud debe verificarse por sí misma con políticas contextuales — no hay confianza implícita por origen.

Problema 02

Identidades con claves estáticas

Los microservicios usaban credenciales persistentes de larga duración en archivos de configuración: un vector permanente de filtración e impersonación.

Problema 03

Conformidad reconfigurada

La reforma constitucional mexicana de 2025 extiende las obligaciones de protección de datos personales explícitamente al cómputo en la nube.

OBJETIVO GENERAL



*Implementar un esquema preventivo unificado para ofrecer **privacidad**, **confidencialidad** e **integridad** de los datos sensibles de la versión en nube de PICIS, mediante la integración de controles técnicos en las funciones de **Identificar** y **Proteger** de acuerdo a los **frameworks** del NIST.*

PROTOCOLO APROBADO · CAP. 1 — OBJETIVO GENERAL

Reporte técnico · Cap. 1 — Antecedentes · §1.5 — cita verbatim del protocolo aprobado por la dirección

OBJETIVOS PARTICULARES

OP-1 · CARACTERIZACIÓN

Caracterizar la brecha de seguridad entre la versión on-premise y la versión de nube de PICIS, con cada activo trazado a un control existente y un control objetivo.

OP-2 · DISEÑO DE CONTROLES

Establecer un conjunto coherente de controles técnicos en *Identificar y Proteger* del NIST CSF 2.0, de modo que cada subcategoría aplicable cuente con al menos un control asociado.

OP-3 · TRAZABILIDAD NORMATIVA

Garantizar la conformidad simultánea con la legislación mexicana y los marcos NIST, de modo que cada artículo aplicable cuente con al menos un control técnico que lo instrumente.

OP-4 · VALIDACIÓN OPERATIVA (TT2)

Demostrar el funcionamiento operativo mediante una matriz de pruebas con un caso por control, criterio numérico de aceptación y evidencia de ejecución.

ESTADO DEL ARTE

APOORTE REPRESENTATIVO	ZT EN GCP	NLP DE PII	PIA CON IA	CONFORMIDAD MX	CMEK · MULTI-TENANT	SIN CLAVES ESTÁTICAS
NIST SP 800-207 · arquitectura ZT	parcial	—	—	—	—	parcial
Microsoft Presidio · Purview (NLP + $F_{\beta=2}$)	—	✓	parcial	—	—	—
Workload Identity Federation (GCP)	✓	—	—	—	parcial	✓
NIST Privacy Framework 1.0 · PIA IA (GAO 2024)	—	—	✓	parcial	—	—
Lineamientos INAI · LGPDPPSO 2025 (MX)	—	—	parcial	✓	—	—
Esquema preventivo PICIS · este TT	✓	✓	✓	✓	✓	✓

TABLA 1. COBERTURA COMPARATIVA CONTRA LOS 6 EJES — FRAGMENTO ILUSTRATIVO DE LA MATRIZ ANALÍTICA COMPLETA CON 23 TRABAJOS (ANEXO H).

Reporte técnico · Cap. 2 — Estado del arte · §2.1-2.7 · Anexo H — matriz analítica

MARCO TEÓRICO · 01

CSF 2.0

NIST Cybersecurity Framework 2.0

Marco rector. El esquema se concentra en las funciones **Identify** y **Protect**. La función *Govern* se ejerce a nivel institución. [1] NIST 2024

Privacy Framework 1.0

Gestión de riesgo de privacidad

Complemento centrado en derechos del titular. Articula PIA y minimización con las funciones del CSF. [2] NIST 2020

SP 800-53 Rev. 5

Catálogo institucional de controles

De su catálogo se derivan y personalizan los **22 controles** del esquema preventivo, ajustados a la realidad de PICIS. [3] NIST 2020

SP 800-207

Zero Trust Architecture

Cada solicitud se evalúa de forma independiente. Sin privilegios por origen ni por ubicación de red. Base del flujo de autorización del esquema. [4] NIST 2020

MARCO TEÓRICO · 02

- **LFPDPPP** (sector privado) · arts. 5, 12, 18-20 — principios de licitud, responsabilidad, calidad y seguridad técnica. [5]
- **Reglamento de la LFPDPPP** · arts. 52 y 57-62 — obligaciones específicas para *cómputo en la nube* y relación responsable–encargado. [6]
- **LGPDPPO** (sujetos obligados) · arts. 25-30, 32-33 — deberes de seguridad y bitácora de vulneraciones. [7]
- **Art. 22 LGPDPSO** — decisiones automatizadas que afectan al titular deben ser explicables y contar con validación humana significativa.
- **Reforma constitucional 2025** — extinguió al INAI y reasignó funciones; sus criterios conservan valor metodológico para el TT.

Reporte técnico · Cap. 3 – Marco teórico · §3.5-3.9 · Anexo E – mapeo normativo bidireccional artículo ↔ control

MARCO TEÓRICO · 03

Adoptada de Microsoft Presidio y Purview como referencia de evaluación del clasificador NLP/IA para TT2. Da el doble de importancia a la *exhaustividad* (recall) que a la *precisión*: en privacidad, los falsos negativos cuestan más que los falsos positivos.

Reporte técnico · Cap. 3 – Marco teórico · §3.10 · Cap. 6 – criterios de aceptación de TT2 (RNF-10)

$$F_{\beta} = (1 + \beta^2) \cdot \frac{precision \cdot recall}{\beta^2 \cdot precision + recall}$$

Con $\beta = 2 \rightarrow$ ponderación favorable al *recall*

HERRAMIENTAS TECNOLÓGICAS

CRITERIO	AWS	MICROSOFT AZURE	GOOGLE CLOUD PLATFORM
Zero Trust nativo · proxy de identidad	Verified Access	Entra Private Access	Identity-Aware Proxy + Access Context Mgr.
Federación sin claves estáticas para workloads	IAM Roles Anywhere · parcial	Managed Identities · parcial	Workload Identity Federation (RFC 8693)
CMEK con HSM gestionado	KMS · CloudHSM	Key Vault HSM	Cloud KMS con HSM y rotación nativa
Clasificación NLP de PII nativa	Macie (limitado a S3)	Purview (catálogo)	Sensitive Data Protection + DLP
Almacenamiento inmutable WORM	S3 Object Lock	Blob immutable storage	Cloud Storage Bucket Lock
Elección del TT	—	—	Mejor integración para una carga NLP institucional bajo ZT

TABLA 2. COMPARATIVA DE PLATAFORMAS CLOUD – CRITERIOS DERIVADOS DE LOS OP Y LOS REQUISITOS NO FUNCIONALES.

Reporte técnico · Cap. 4 – Análisis · §4.3 – selección de plataforma. Anexo B – comparativa extendida.

METODOLOGÍA



ETAPA 01

Caracterización de la brecha

Activos del on-premise vs nube.
Control existente vs control objetivo.

TT1



ETAPA 02

Análisis normativo

Mapeo bidireccional artículo ↔ control con LFPDPPP, LGPDPPSO y NIST.

TT1



ETAPA 03

Diseño de controles

22 controles instrumentados en GCP, agrupados en C / I / P. Cubren *Identify* y *Protect*.

TT1



ETAPA 04

Análisis de impacto (PIA)

PIA del módulo de clasificación NLP/IA en siete bloques. Decisión residual documentada.

TT1



ETAPA 05

Despliegue y pruebas

Aprovisionamiento declarativo, matriz de pruebas con caso por control y evidencia operativa.

TT2

ANÁLISIS

ACTIVO / SUPERFICIE	CONTROL EXISTENTE (ON-PREMISE)	CONTROL OBJETIVO (NUBE)
Identidad de microservicios	Claves estáticas en archivos de configuración	Workload Identity Federation · tokens ≤ 1 h
Acceso a backend de aplicación	Perímetro de red interna · firewall	Identity-Aware Proxy + Access Context Manager
Cifrado en reposo de datos sensibles	Cifrado de volumen genérico	Cloud KMS con CMEK · DEK por dataset
Bitácora de auditoría	Logs locales en disco	Cloud Audit Logs en Bucket Lock WORM
Clasificación de PII en documentos scrapeados	Reglas locales del clasificador	SDP + clasificador NLP/IA del esquema
Decisión automatizada del clasificador	Sin registro de explicabilidad	Trazabilidad + validación del Analista (art. 22)

TABLA 3. FRAGMENTO DE LA MATRIZ DE BRECHA – LA COMPLETA SE ENCUENTRA EN EL ANEXO I.

REQUISITOS

Cada requisito tiene criterio de aceptación medible y trazabilidad explícita al OP y al control del catálogo que lo materializa.

12 funcionales

Qué debe hacer el esquema

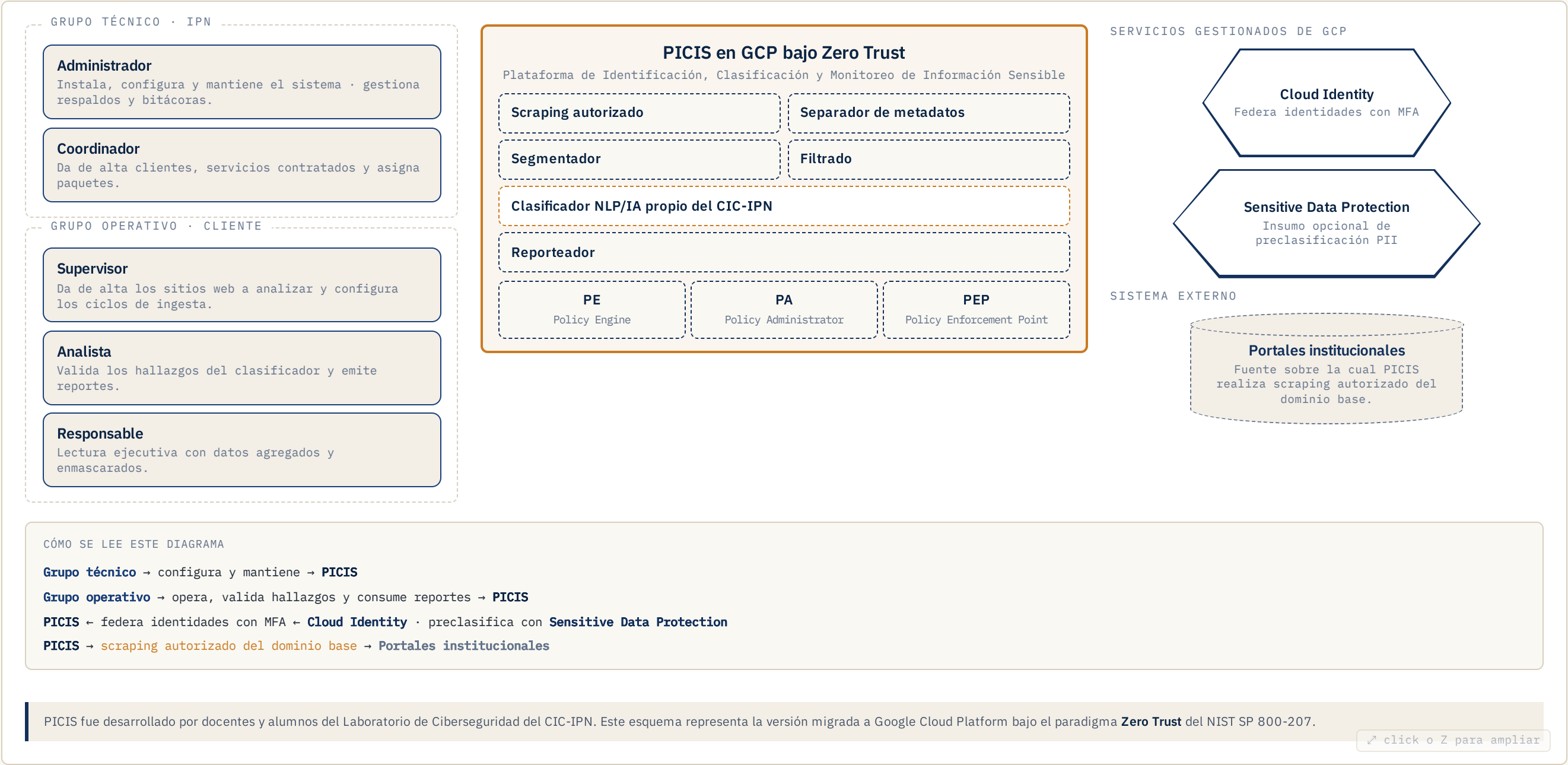
- **RF-02** · clasificar PII en cuatro niveles (N1-N4)
- **RF-04** · acceso Zero Trust por contexto
- **RF-05 / 06** · cifrado en reposo y tránsito con CMEK
- **RF-07** · logs inmutables en Bucket WORM
- **RF-12** · trazabilidad de decisiones de IA

10 no funcionales

Cómo debe comportarse

- **RNF-01** · cumplimiento legal mexicano
- **RNF-02** · alineación NIST CSF 2.0
- **RNF-08** · aprovisionamiento declarativo reproducible
- **RNF-09** · reducción verificable de superficie
- **RNF-10** · verificabilidad de pruebas — cada caso reproducible con evidencia de ejecución

DISEÑO · ARQUITECTURA C4 NIVEL 1



DISEÑO · ARQUITECTURA C4 NIVEL 2



Fig. 2. Diagrama C4 nivel 2 – cinco planos lógicos que sostienen el esquema preventivo de privacidad sobre Google Cloud Platform.

DISEÑO • FLUJO DE AUTORIZACIÓN ZERO TRUST



Fig. 3. Flujo de autorización Zero Trust en 11 pasos – cuatro planos (ingreso, aplicación, datos, auditoría) sobre PICIS en Google Cloud Platform.

DISEÑO · ARQUITECTURA C4 NIVEL 3

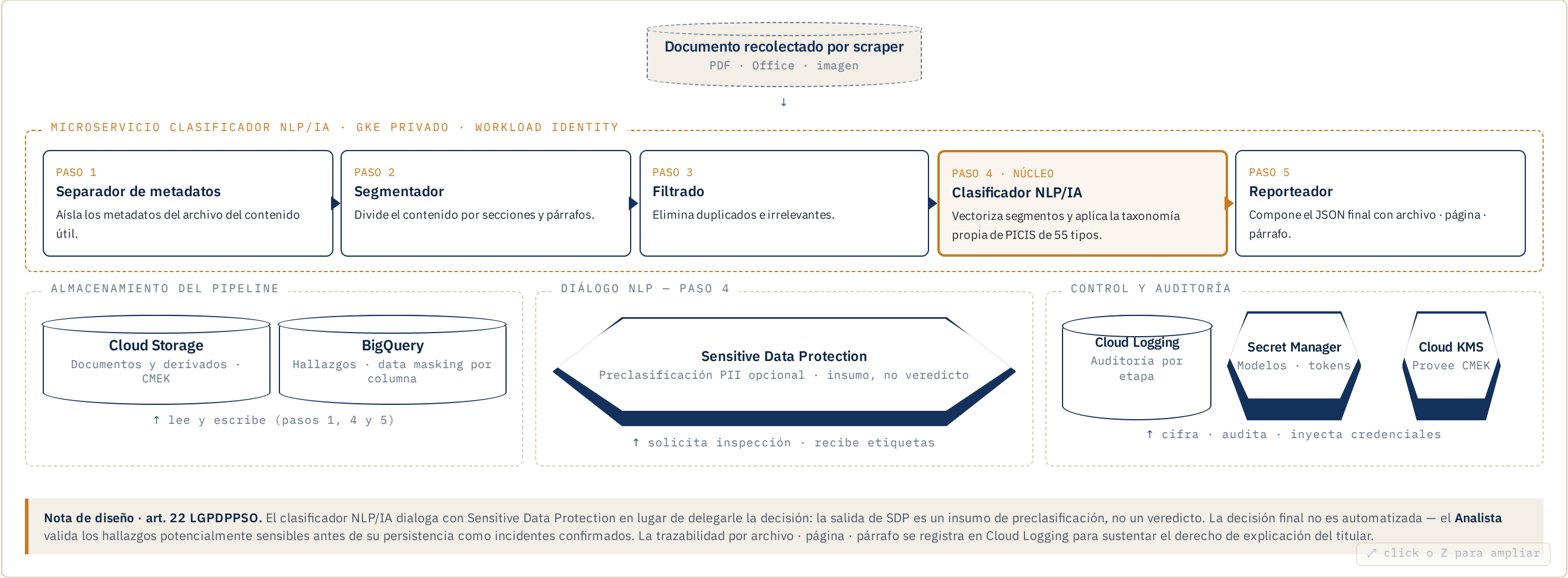


Fig. 4. Diagrama C4 nivel 3 – cinco componentes encadenados dentro del microservicio en GKE.

DISEÑO · CATÁLOGO

8 controles · C-001 → C-008

Confidencialidad

- **C-001** · cifrado en reposo con CMEK
- **C-002** · cifrado en tránsito TLS 1.3
- **C-003** · MFA e identidades federadas
- **C-004** · acceso contextual con IAP
- **C-006** · VPC Service Controls

7 controles · I-001 → I-007

Integridad

- **I-001** · inventario automático de activos
- **I-002** · firmas SHA-256 de snapshots
- **I-003** · logs inmutables Bucket Lock
- **I-006** · firma de imágenes GKE

7 controles · P-001 → P-007

Privacidad

- **P-001** · clasificación Cloud SDP
- **P-002** · minimización por finalidad
- **P-003** · enmascaramiento BigQuery
- **P-006/07** · consentimiento y PIA

DISEÑO · ANÁLISIS DE IMPACTO A LA PRIVACIDAD

El PIA evalúa el tratamiento automatizado de PII por el clasificador NLP/IA y establece medidas para neutralizar riesgos antes del despliegue productivo.

Art. 22 LGPDPPSO · validación humana

Las decisiones automatizadas deben ser explicables. El **Analista** de PICIS interviene como validación humana significativa antes de consolidar cualquier incidente. El esquema preserva esta intervención y la trazabiliza con Audit Logs.

- B-01 Descripción del tratamiento — flujo del pipeline
- B-02 Categorías de datos — niveles N1-N4
- B-03 Actores y encargados — Google Cloud bajo art. 52 Reglamento
- B-04 Finalidad y base jurídica
- B-05 Riesgos a derechos y libertades — siete riesgos (R1-R7)
- B-06 Controles mitigantes — del catálogo
- B-07 Decisión residual — riesgo medio, mitigar antes de producción

RESULTADOS PARCIALES Y AVANCES OBTENIDOS

- **OP-1 cumplido** — brecha caracterizada con cada activo trazado a un control existente y un control objetivo.
- **OP-2 cumplido** — 22 controles diseñados y mapeados a las subcategorías aplicables del NIST CSF 2.0.
- **OP-3 cumplido** — conformidad normativa trazada artículo ↔ control sobre LFPDPPP, Reglamento y LGPDPPSO.
- **PIA en siete bloques** — entregado para el módulo de clasificación NLP/IA con decisión residual documentada.

Reporte técnico · Cap. 7 – Avances y resultados parciales TT1

Trazabilidad obtenida

Mapeo bidireccional artículo ↔ control

Cada control del catálogo queda trazado al artículo legal que lo exige (LFPDPPP, LGPDPPSO, Reglamento) y a la subcategoría NIST CSF 2.0 que lo norma. El mapeo inverso — artículo a control — está documentado en el Anexo E del reporte técnico.

TRABAJO A FUTURO

- **Aprovisionamiento declarativo** del proyecto productivo en GCP — scripts reproducibles que el equipo o un tercero pueden ejecutar y obtener el mismo entorno.
- **Matriz de pruebas** con un caso por control, criterio numérico de aceptación y evidencia de ejecución (cumplimiento del OP-4).
- **Validación operativa** del clasificador NLP/IA con $F_{\beta=2}$ como criterio de aceptación. Ponderación favorable al recall.
- **Auditoría inversa** — verificar que cada artículo legal aplicable es satisfecho por al menos un control con evidencia material.



DEFENSA TT1 · 27 DE MAYO DE 2026

Gracias por su *atención.*

*Esquema preventivo de privacidad para
PICIS en la versión de nube basado en la
arquitectura Zero Trust*

EQUIPO

Francisco López Carlos Uriel · Leyva García Diego Alejandro · Romero Carreón Miguel Arturo

DIRECTORES

Dra. Cortez Duarte Nidia Asunción · Dr. Aguirre Anaya Eleazar

Trabajo Terminal 2026-B182